ISEP

Segurança de Sistemas e Informação (SEGSI)
PL08
Joaquim Filipe Peixoto dos Santos (**JPE**)
Pedro Filipe Cruz Pinto (**PFP**)
Dílio Adalberto da Rocha Ribeiro (**DAR**)
Daniela Alexandra Pires Pinto (**DPI**)
{ @isep.ipp.pt }

Exercise 1: Deploying the environment

With the advent of new paradigms such as shift-left[1] and GitOps[2] a new attack surface emerges. Jenkins and all the components that comprise a complete CI/CD pipeline. In this exercise, we will deploy several services to enable us to understand what misconceptions and security mishaps might occur.

1. Go to the Github Repository[3] and follow the Take the challenge section.
2. Be sure to have at least 10GB of RAM available in your machine since several services will be running.
3. What kind of attacks[4] might be portrayed in such environments?
4. If this opens a new attack surface, why are companies moving to this paradigm? Compare the threats and the benefits.

This environment consists of several challenges for you to learn and experiment tackle each one with the mindset of an attacker to leverage the CI/CD pipeline in your favor.

5. **Follow the White Rabbit** investigate the credential store of the Jenkins installation and retrieve the flag.
6. **Mad Hater**. Investigate what commands are being executed and how can you leverage them to gain access to the flag.
7. **Caterpillar** with ReadOnly access we have access to sensitive information. Investigate what information you have access to and can leverage to compromise the pipeline.
8. What are your considerations in trying to bring security to these types of accesses? What would you do to prevent such mistakes?

[1] https://www.dynatrace.com/news/blog/what-is-shift-left-and-what-is-shift-right/
[2] https://about.gitlab.com/topics/gitops/
[3] https://github.com/cider-security-research/cicd-goat#Linux--Mac
[4] https://cheatsheetseries.owasp.org/cheatsheets/CI_CD_Security_Cheat_Sheet.html